SÉCURITÉ DES SYSTÈMES
M1 CYSIA (S2)

M. MEDEDJEL

2025-2026

COURS 2 : L’AUTHENTIFICATION

OBJECTIFS

Les objectifs principaux :

- Discutez les différents moyens d'authentification de l'identité.
- Expliquer le mécanisme par lequel les mots de passe sont utilisés pour l'authentification des utilisateurs.
- Présenter un aperçu de l'authentification des utilisateurs basée sur les jetons et la biométrie.
- Résumer certains problèmes et approches dans l'authentification des utilisateurs à distance.

INTRODUCTION

Dans le contexte de la sécurité informatique, l'authentification est l'élément fondamental et la première ligne de défense.

L'authentification englobe deux fonctions :

- Premièrement, l'utilisateur s'identifie auprès du système en présentant un justificatif, comme l'ID de l'utilisateur.
- Ensuite, le système vérifie l'utilisateur par l'échange d'informations d'authentification.

INTRODUCTION

Par exemple, l'utilisateur « **Ali »** pourrait avoir l'ID: **Ali-2026**.

- Cette information doit être stockée sur tout serveur ou système utilisé par « Ali », et pourrait être connue des administrateurs système et des autres utilisateurs.
- Une information d'authentification typique associée à cet **ID** est le **mot de passe**, qui est gardé secret (seul Ali et le système en connaissent le code).
- L'association de l'ID et du mot de passe permet aux administrateurs de configurer les autorisations d'accès d'Ali et d'auditer son activité.

INTRODUCTION

Essentiellement,

- ✓ **L'identification:** est une étape où un utilisateur fournit au système une identité revendiquée.
- ✓ **L'authentification**: étape suivante où le système vérifie la validité de la revendication.

INTRODUCTION

❖ **Remarque**:

Il convient de noter que l'authentification de l'utilisateur est distincte de l'authentification des messages.

- l’authentification de l’utilisateur consiste à s’assurer que la personne/entité est bien celle qu’elle prétend être.
- l’authentification des messages permet aux participants de vérifier qu’un message n’a pas été modifié en route et qu’il provient bien de l’émetteur attendu.

INTRODUCTION

- Ce cours porte uniquement sur l'authentification des utilisateurs.
- Il commence par fournir une vue d'ensemble des différents moyens d'authentification, puis examine chacun d'entre eux en détail.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Déf. *NIST SP 800-63-3 (Digital Authentication Guideline, October 2016) defines digital user authentication as the process of establishing confidence in user identities that are presented electronically to an information system.*

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

- Une fois l'identité authentifiée, le système s'appuie dessus pour décider si la personne a le droit d'exécuter certaines opérations (par exemple lancer une transaction sur une base de données ou accéder à une ressource système).
- L'authentification puis l'autorisation peuvent se faire aussi bien dans un environnement local (réseau d'entreprise, LAN) que sur un réseau ouvert comme Internet.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs

NIST SP 800-63-3 définit un modèle général pour l'authentification qui implique un certain nombre d'entités et de procédures (voir Figure 1).

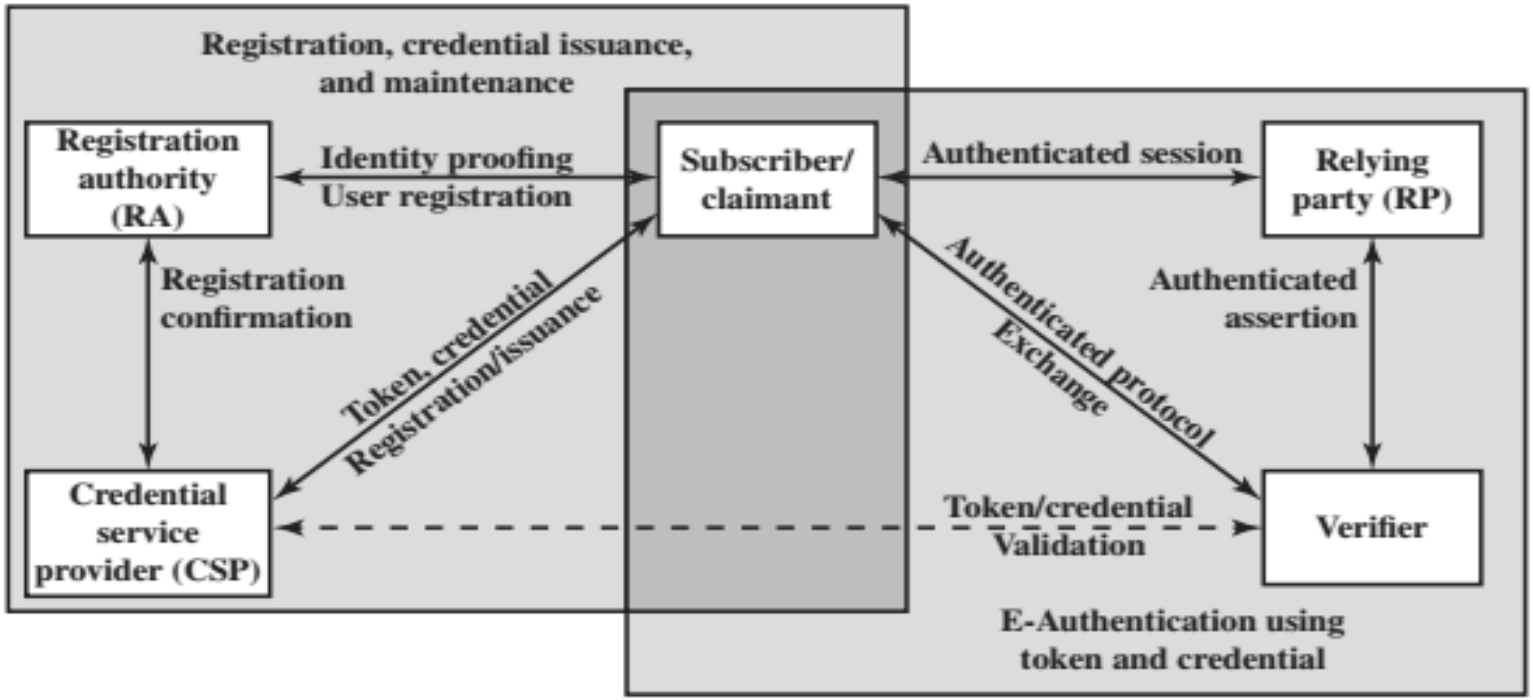


Figure 1. Le modèle architectural d'authentification électronique (NIST SP 800-63-3)

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

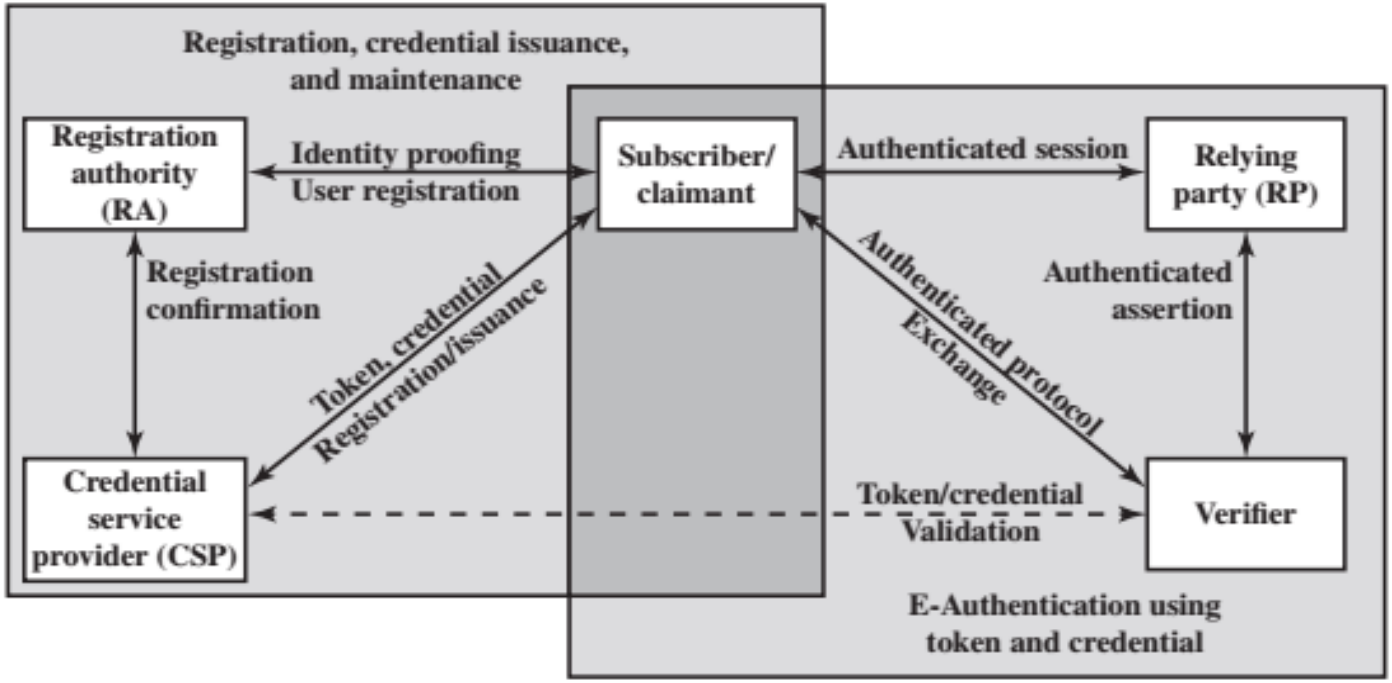
Modèle d'authentification numérique des utilisateurs

La condition initiale pour effectuer l'authentification de l'utilisateur est qu'il doit être enregistré auprès du système.

Dans ce qui suit une séquence typique d'enregistrement.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs

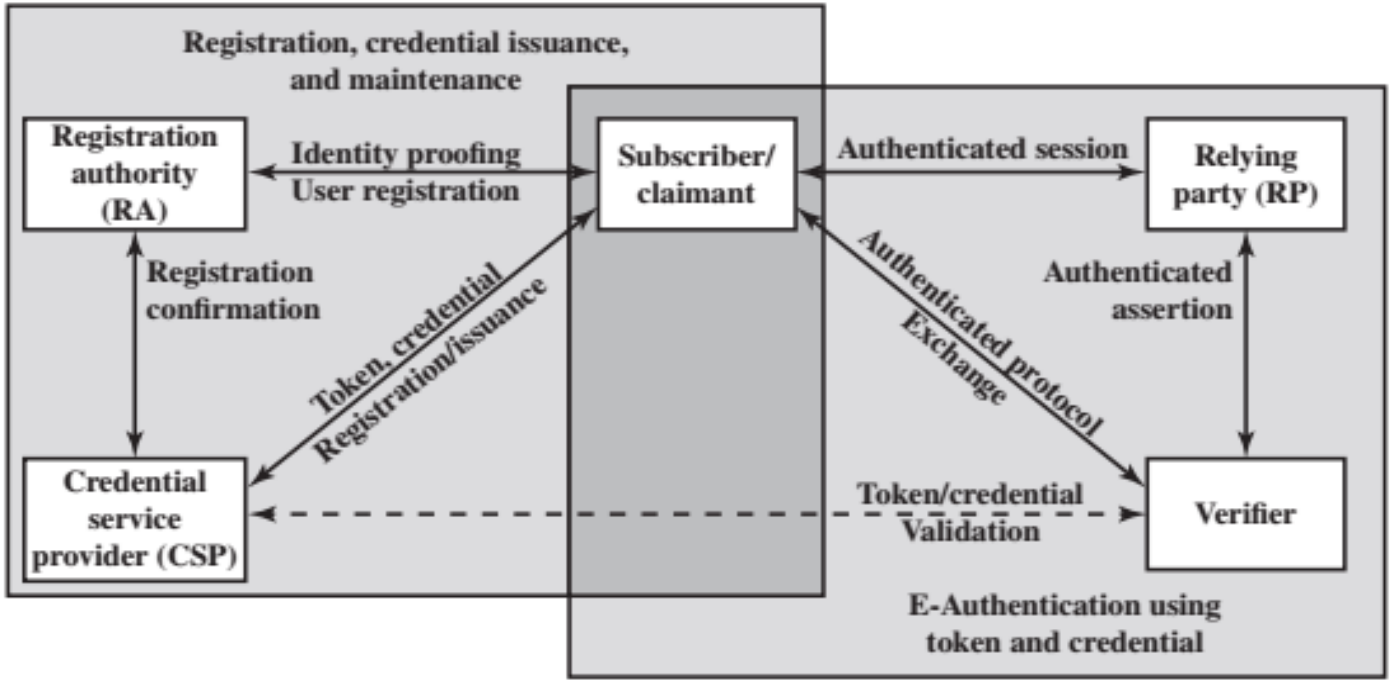


Un candidat s'adresse à une autorité d'enregistrement (RA) pour devenir un abonné d'un fournisseur de services d'accréditation (CSP).

Dans ce modèle, la RA est une entité de confiance qui établit et garantit l'identité d'un demandeur auprès d'un CSP.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs

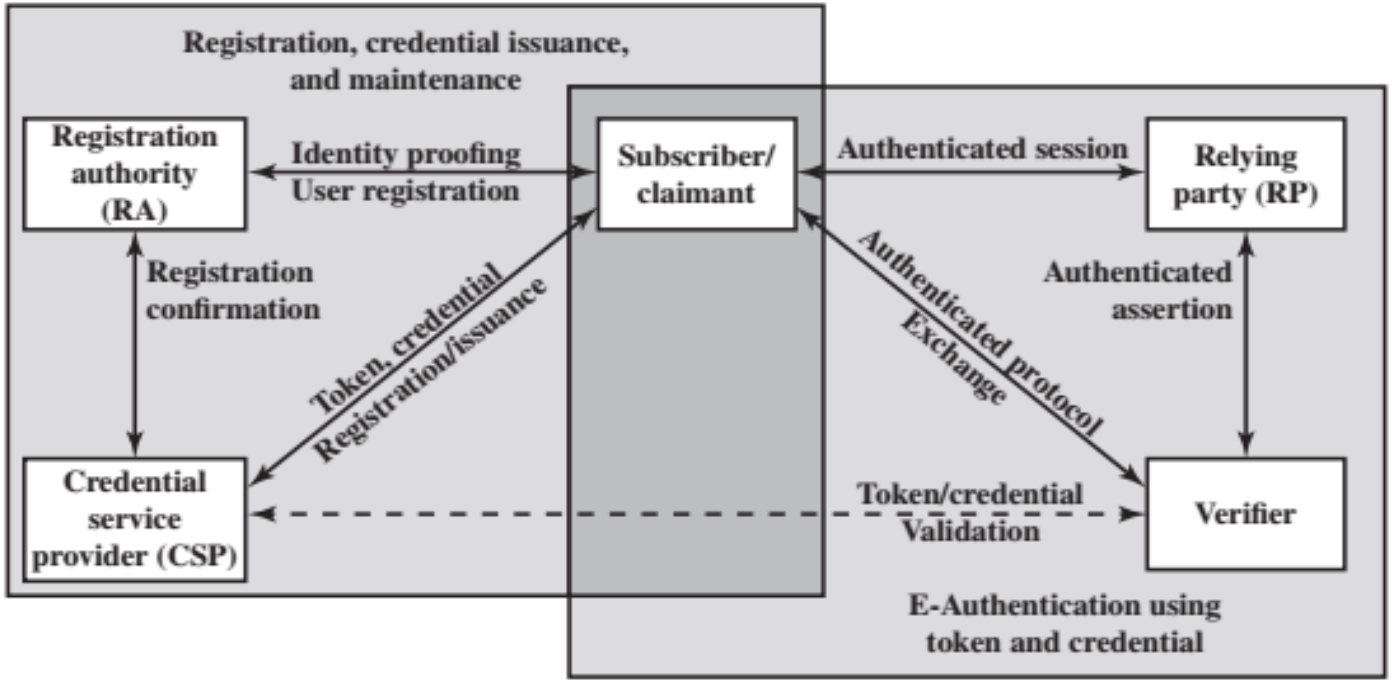


Le CSP procède ensuite à un échange avec l'abonné.

En fonction des détails du système d'authentification global, le CSP délivre une sorte de justificatif électronique à l'abonné.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

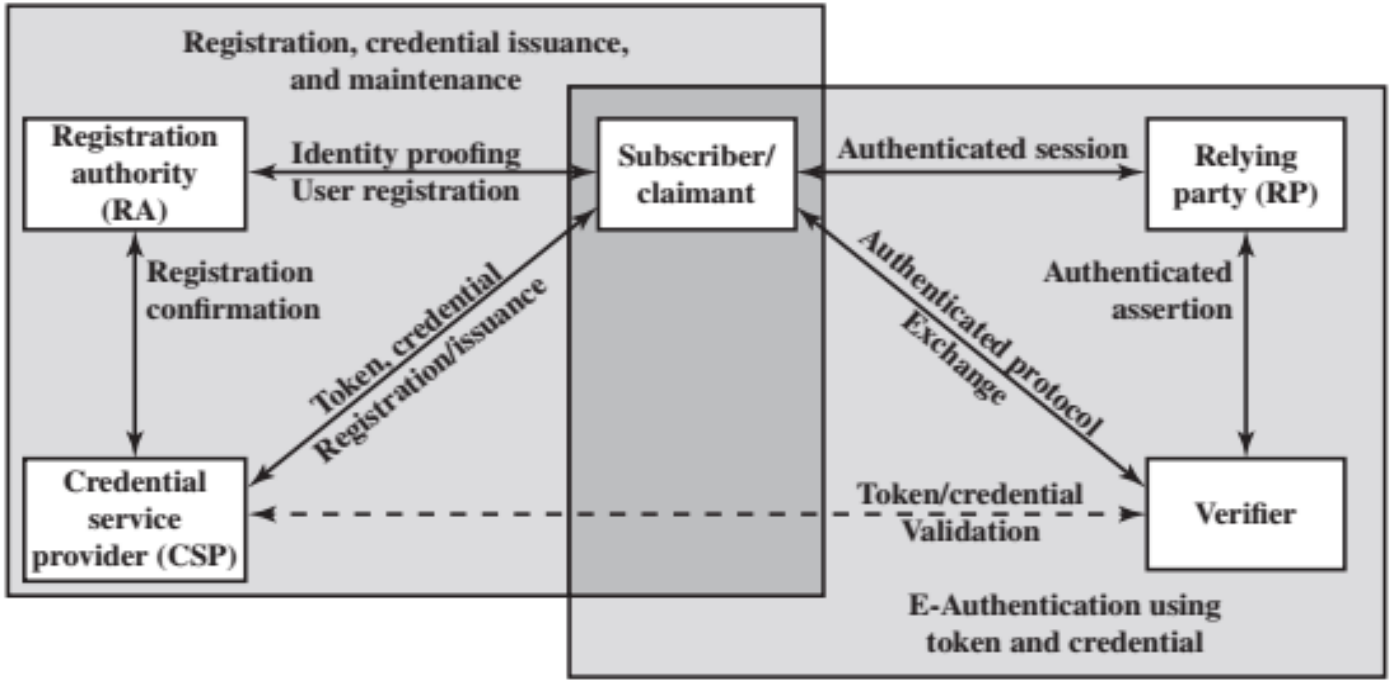
Modèle d'authentification numérique des utilisateurs



Un justificatif est une structure de données qui associe de façon garantie une identité et certains attributs à un jeton détenu par un abonné, et qui peut être vérifiée au moment d'une transaction d'authentification.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs



Le jeton peut être une clé de chiffrement ou un mot de passe chiffré qui identifie l'abonné.

Il peut être émis par le CSP, généré directement par l'abonné, ou fourni par un tiers.

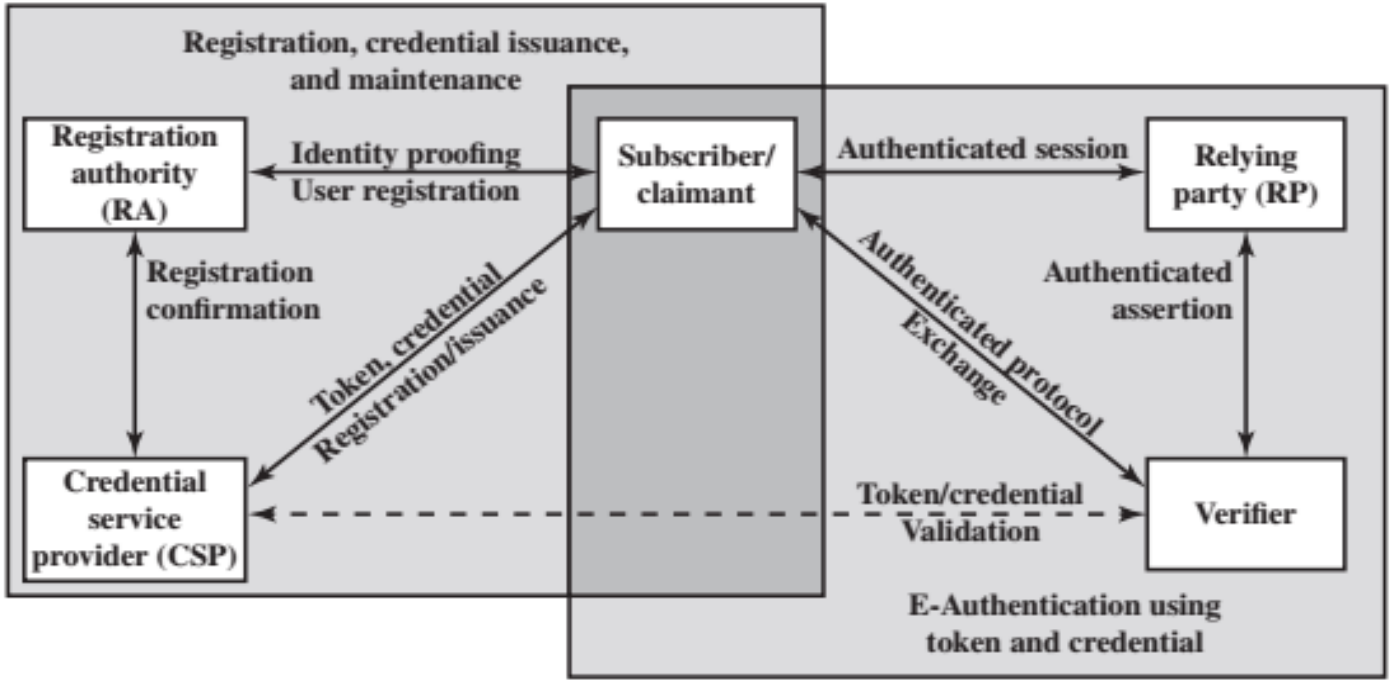
PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs

Une fois qu’un utilisateur a été enregistré comme abonné, le processus d’authentification proprement dit peut s’effectuer entre cet abonné et un ou plusieurs systèmes, qui vont d’abord vérifier son identité puis décider des droits d’accès (autorisation) à lui accorder.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

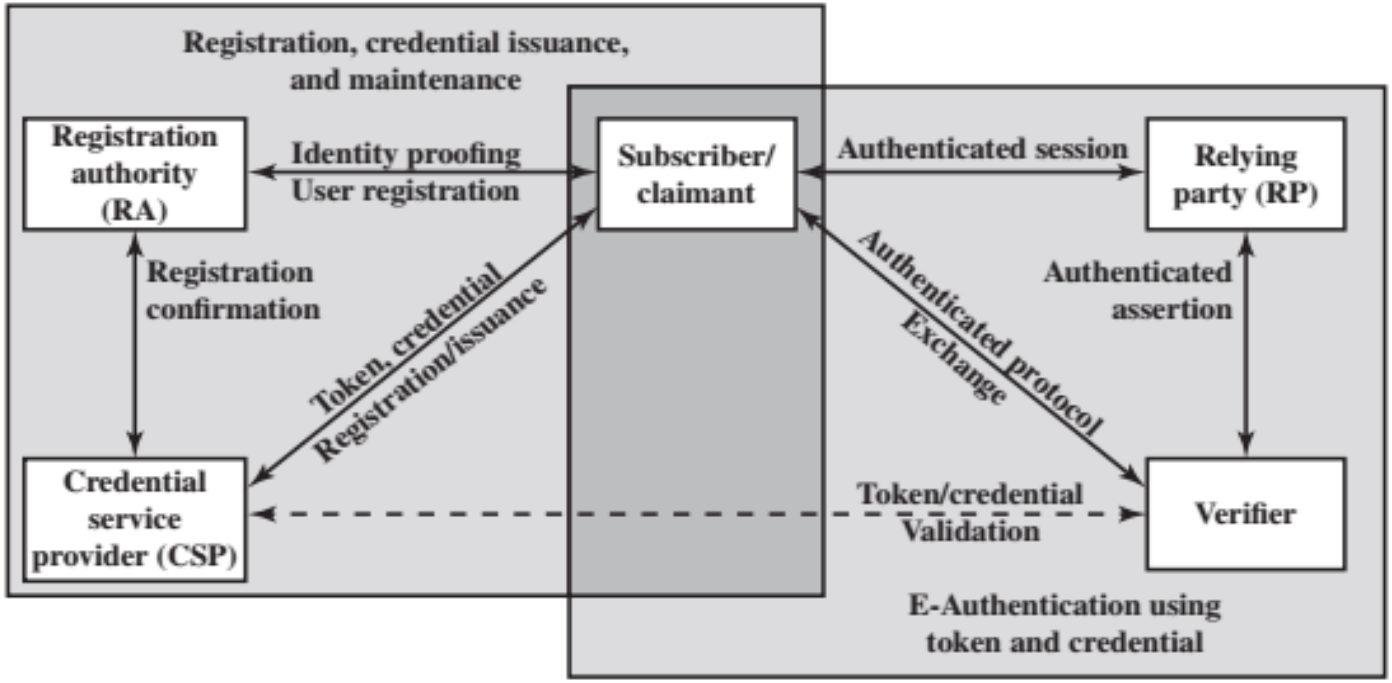
Modèle d'authentification numérique des utilisateurs



La partie à authentifier est appelée demandeur (***claimant***) et la partie qui vérifie cette identité est appelée vérificateur (***verifier***).

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

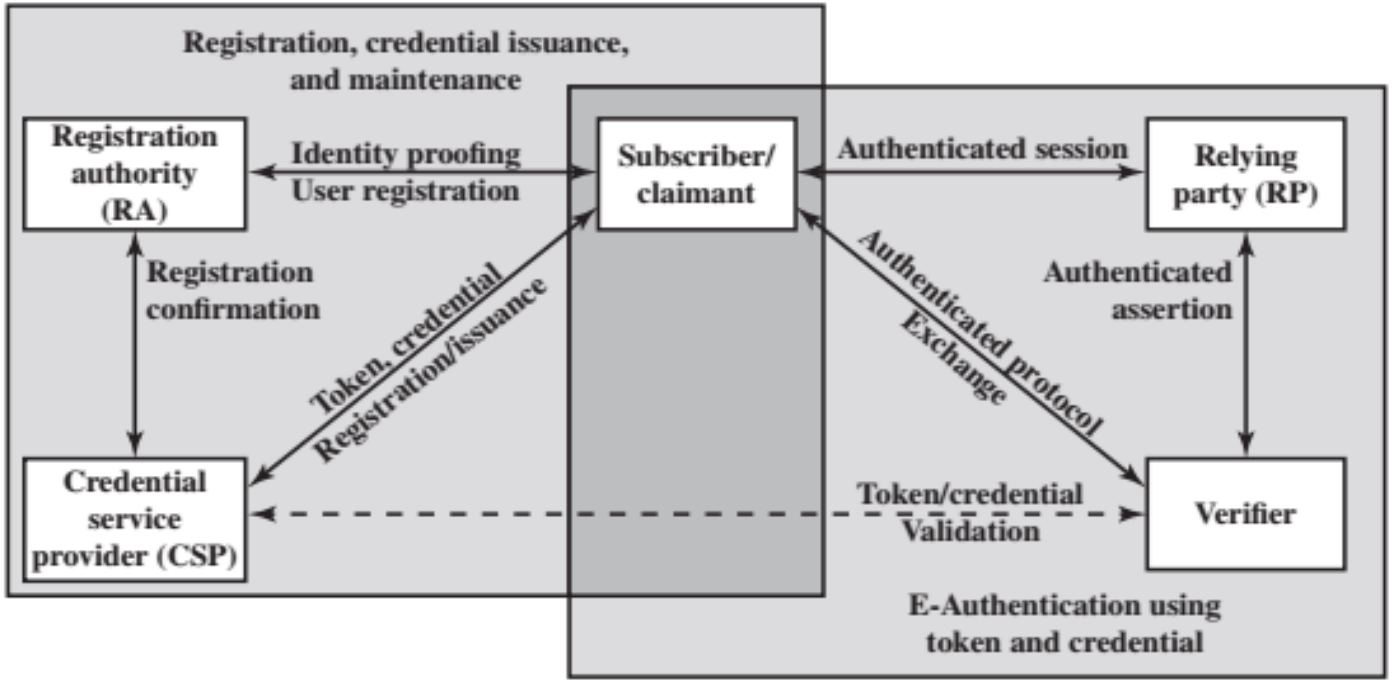
Modèle d'authentification numérique des utilisateurs



Lorsqu'un demandeur démontre avec succès la possession et le contrôle d'un jeton à un vérificateur à l'aide d'un protocole d'authentification, le vérificateur contrôle la validité du jeton/justificatif.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

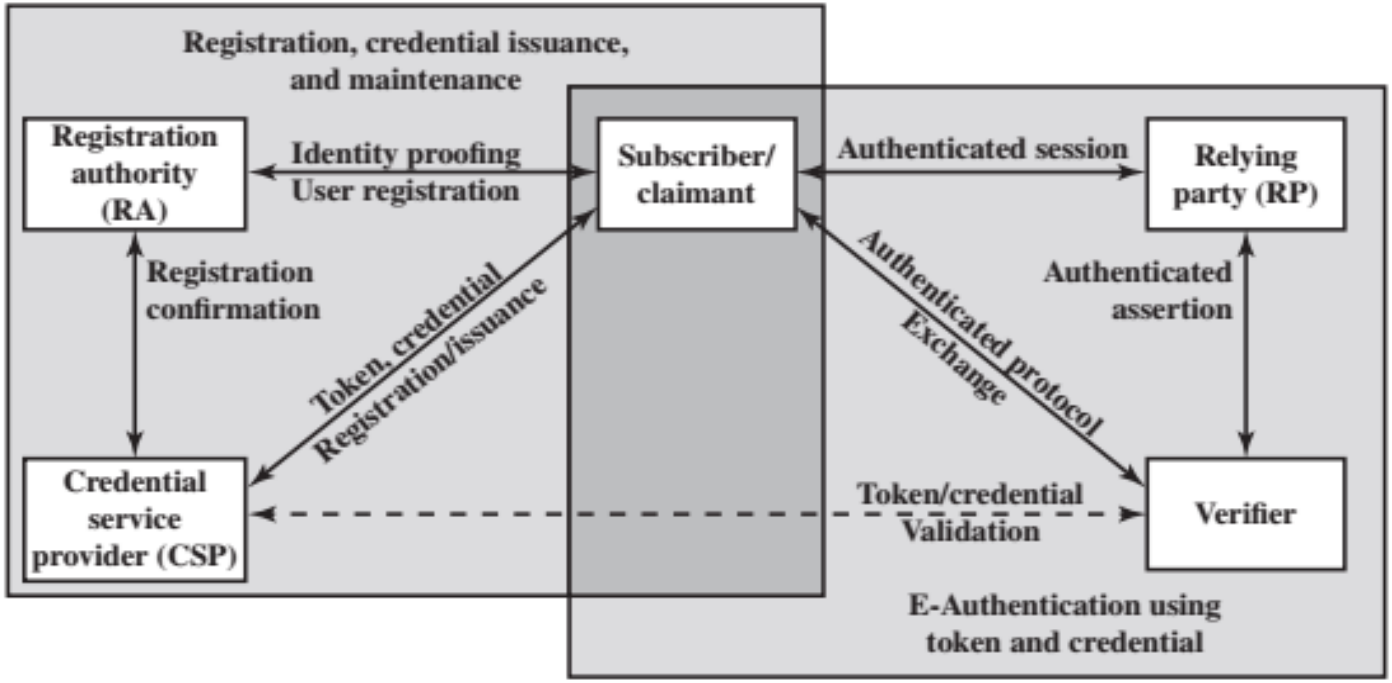
Modèle d'authentification numérique des utilisateurs



Le vérificateur transmet une assertion à la partie de confiance (RP). Cette assertion comprend des informations sur l'identité de l'abonné, telles que le nom, l'identifiant attribué lors de l'enregistrement ou d'autres attributs qui ont été vérifiés lors du processus d'enregistrement.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Modèle d'authentification numérique des utilisateurs



La RP peut utiliser les informations authentifiées fournies par le vérificateur pour prendre des décisions de contrôle d'accès ou d'autorisation.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Remarque :

Dans la pratique, l'implémentation d'un système d'authentification est souvent plus riche et plus complexe que ce modèle simplifié. Celui-ci sert avant tout à mettre en évidence les principaux rôles (abonné, autorité d'enregistrement, fournisseur de justificatifs, vérificateur, service applicatif) et les fonctions essentielles pour concevoir un système d'authentification réellement sécurisé.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

Il existe quatre méthodes générales d'authentification de l'identité d'un utilisateur, qui peuvent être utilisées seules ou en combinaison :

i. **Quelque chose que la personne connaît** :

- mot de passe, numéro d'identification personnel (NIP) ou réponses à une série de questions préétablies.

ii. **Quelque chose que la personne possède** :

- cartes électroniques, cartes à puce ou clés physiques. Ce type d'authentificateur est appelé « jeton ».

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

iii. **Quelque chose que l'individu est (biométrie statique)** :

- la reconnaissance des empreintes, du visage ou de la rétine/Iris**.**

iv. **Ce que fait la personne (biométrie dynamique)** :

- la reconnaissance du modèle vocal, des caractéristiques de l'écriture manuscrite et du rythme de frappe.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

Toutes ces méthodes peuvent fournir une authentification sécurisée, à condition d'être correctement mises en œuvre et utilisées. Cependant, chacune d'entre elles peut présenter des inconvénients.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

Par exemple:

- Un utilisateur peut oublier un mot de passe ou perdre un jeton.
- Un adversaire peut être capable de deviner ou de voler un mot de passe. De même, il peut être capable de contrefaire ou de voler un jeton.
- La gestion des informations de mot de passe, de jeton et la sécurisation de ces données sur les systèmes entraînent une charge administrative importante.
- En ce qui concerne les authentificateurs biométriques, il existe une variété de problèmes, notamment le traitement des faux positifs et des faux négatifs, l'acceptation par l'utilisateur, le coût et la commodité.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

- L'authentification multifactorielle (MFA ou Multi-Factor Authentication) désigne l'utilisation de deux moyens d'authentification ou plus.
- La force d'un système d'authentification est étroitement liée au nombre de facteurs qu'il prend en compte.
  - Les implémentations utilisant deux facteurs sont considérées comme plus sûres que celles qui n'utilisent qu'un seul facteur ; les systèmes qui intègrent trois facteurs sont plus robustes que ceux qui n'en intègrent que deux, et ainsi de suite.

PRINCIPES D'AUTHENTIFICATION NUMÉRIQUE DES UTILISATEURS

Les moyens d'authentification

La figure 2 illustre un exemple d'authentification multifacteur.

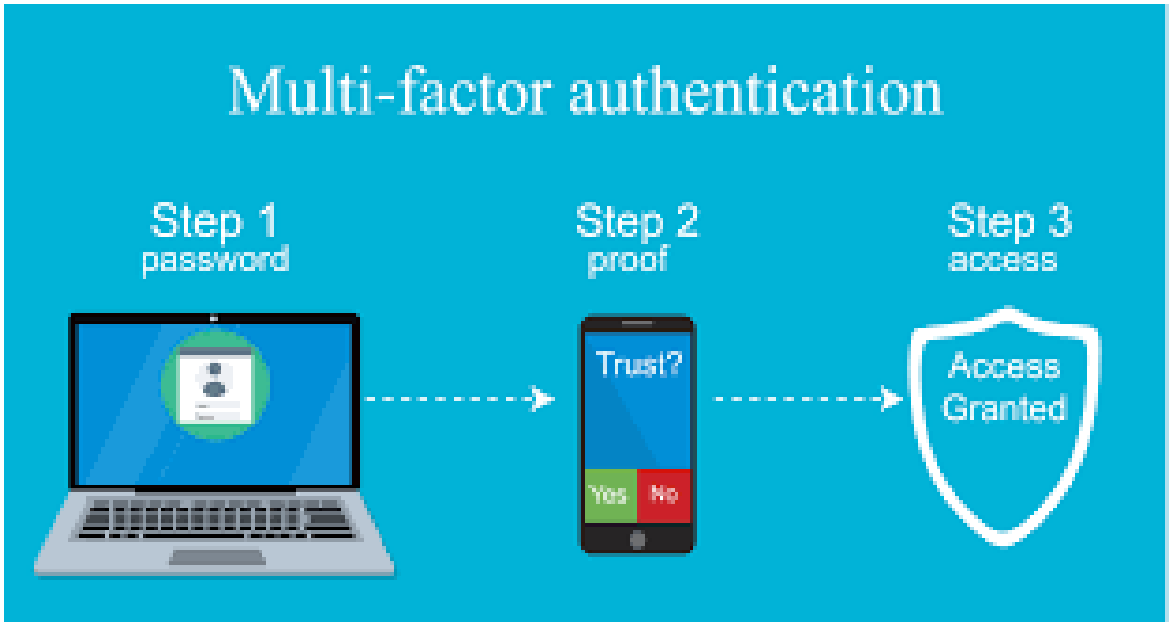


Figure 2. Authentification multifacteur.

AUTHENTIFICATION PAR MOT DE PASSE

Les systèmes de mots de passe constituent une des premières lignes de défense contre les accès non autorisés.

Dans la plupart des environnements multi-utilisateurs (serveurs, applications web, etc.), l'utilisateur doit fournir un identifiant (login) et un mot de passe. Le système compare alors le mot de passe saisi avec la valeur associée à cet identifiant, enregistrée dans un fichier de mots de passe du système (en pratique, sous forme protégée).

AUTHENTIFICATION PAR MOT DE PASSE

Le mot de passe sert à authentifier l'ID de la personne qui se connecte au système. À son tour, l'ID assure la sécurité de la manière suivante :

- Il détermine si l'utilisateur est autorisé à accéder à un système. Seuls ceux ayant un ID enregistré sur le système peuvent se connecter.
- Il détermine les privilèges accordés à l'utilisateur.
  - certains comptes ont un rôle administrateur / super-utilisateur, avec des droits étendus (lecture de tous les fichiers, actions sensibles au niveau du système d'exploitation) ;
  - d'autres sont des comptes invités ou anonymes, avec des droits très limités.
- Il est utilisé dans ce que l'on appelle le contrôle d'accès discrétionnaire.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

- Dans cette sous-section, nous décrivons les principales formes d'attaque contre l'authentification par mot de passe et exposons brièvement une stratégie de contre-mesure.
- En général, un système qui utilise l'authentification par mot de passe maintient un fichier de mots de passe indexé par l'ID utilisateur.
- Une technique généralement utilisée consiste à stocker un code à sens unique du mot de passe au lieu du mot de passe lui même.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

Généralement, nous pouvons identifier les stratégies d'attaque et les contre-mesures suivantes :

× **Attaque par dictionnaire hors ligne (*Offline dictionary attack*)** : si un attaquant parvient à récupérer le fichier de mots de passe d'un système, il peut tester, en local, de très nombreux mots de passe probables (listes de mots courants, fuites connues, etc.) jusqu'à trouver une correspondance entre un hachage du fichier et un mot de passe de son dictionnaire. Une fois cette correspondance trouvée, il obtient un couple ID/mot de passe valide et peut se connecter comme l'utilisateur.

✓ Les contre-mesures comprennent des contrôles pour empêcher l'accès non autorisé au fichier des mots de passe, des mécanismes de détection d'intrusions pour identifier toute compromission et la réinitialisation rapide des mots de passe si le fichier est compromis.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

× **Attaque de compte spécifique (*Specific account attack*)** : L'attaquant cible un compte spécifique et soumet des mots de passe jusqu'à ce qu'il découvre le bon mot de passe.

✓ La contre-mesure standard est un mécanisme de verrouillage qui bloque l'accès au compte après un certain nombre de tentatives de connexion infructueuses. La pratique habituelle est de ne pas dépasser plus de cinq tentatives d'accès.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

× **Attaque par mot de passe populaire (*Popular password attack*)** : Cette attaque (variante de la précédente) consiste à tester quelques mots de passe très courants (par exp 123456, password, admin, etc.) sur un grand nombre de comptes utilisateurs. Comme beaucoup de personnes choisissent des mots de passe faciles à retenir, ces essais ont souvent du succès.

✓ Les contre-mesures comprennent des politiques interdisant les mots de passe trop simples ou trop fréquents et la surveillance et l'analyse des tentatives d'authentification (adresses IP, volumes d'essais) pour détecter et bloquer rapidement ce type d'attaque.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

× **Deviner le mot de passe d'un seul utilisateur (*Password guessing against single user*)** : L'attaquant collecte des informations sur la personne (nom, date de naissance, centres d'intérêt, habitudes) ainsi que sur les règles de mot de passe du système, puis essaie des mots de passe construits à partir de ces éléments (nom+année, prénom-date de naiss, etc.).

✓ Les contre-mesures comprennent l'application de politiques qui rendent les mots de passe difficiles à deviner (la longueur minimale du mot de passe, le jeu de caractères et l'interdiction d'utiliser des identifiants d'utilisateurs connus).

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

× **Détournement de poste de travail (*Workstation hijacking*)** : L'attaquant attend qu'un poste de travail connecté soit sans surveillance.

✓ La contre-mesure standard consiste à déconnecter automatiquement le poste de travail après une période d'inactivité. Les systèmes de détection d'intrusion peuvent être utilisés pour détecter les changements de comportement des utilisateurs.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

- × **Exploitation de l'utilisation de mots de passe multiples (*Exploiting multiple password use*)** : Les attaques peuvent également devenir beaucoup plus efficaces ou dommageables si différents périphériques réseau partagent le même mot de passe ou un mot de passe similaire pour un utilisateur donné.
- ✓ Les contre-mesures incluent une politique qui interdit l'utilisation d'un mot de passe identique ou similaire sur certains périphériques réseau.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

× **Surveillance électronique (*Electronic monitoring*)** : désigne le fait qu'un attaquant écoute le trafic réseau pour intercepter les identifiants envoyés lors de la connexion à un système distant. Quand un mot de passe est transmis sur le réseau, il peut être capturé.

Un simple cryptage ne résout pas ce problème, car le mot de passe crypté est, en fait, le mot de passe et peut être observé et réutilisé par un adversaire.

✓ Les contre-mesures incluent l'utilisation des protocoles résistants au rejeu (défi-réponse, OTP) plutôt que d'envoyer un mot de passe réutilisable, le chiffrement de la session (TLS/HTTPS, VPN) et, si possible, ajouter une authentification multifacteur.

AUTHENTIFICATION PAR MOT DE PASSE

La vulnérabilité des mots de passe

Malgré leurs nombreuses faiblesses en matière de sécurité (faciles à deviner, à voler, à réutiliser, etc.), les mots de passe restent aujourd'hui le mécanisme d'authentification le plus répandu.

- **D'après vous, pourquoi ?**

AUTHENTIFICATION PAR MOT DE PASSE

L'utilisation de mots de passe hachés

Une technique de sécurité des mots de passe largement utilisée est l'utilisation de mots de passe **hachés** et d'une valeur appelée **sel (*salt*).**

Ce schéma est présent pratiquement sur toutes les variantes d'UNIX ainsi que sur un certain nombre d'autres systèmes d'exploitation.

La procédure utilisée est illustrée dans la figure suivante.

AUTHENTIFICATION PAR MOT DE PASSE

L'utilisation de mots de passe hachés

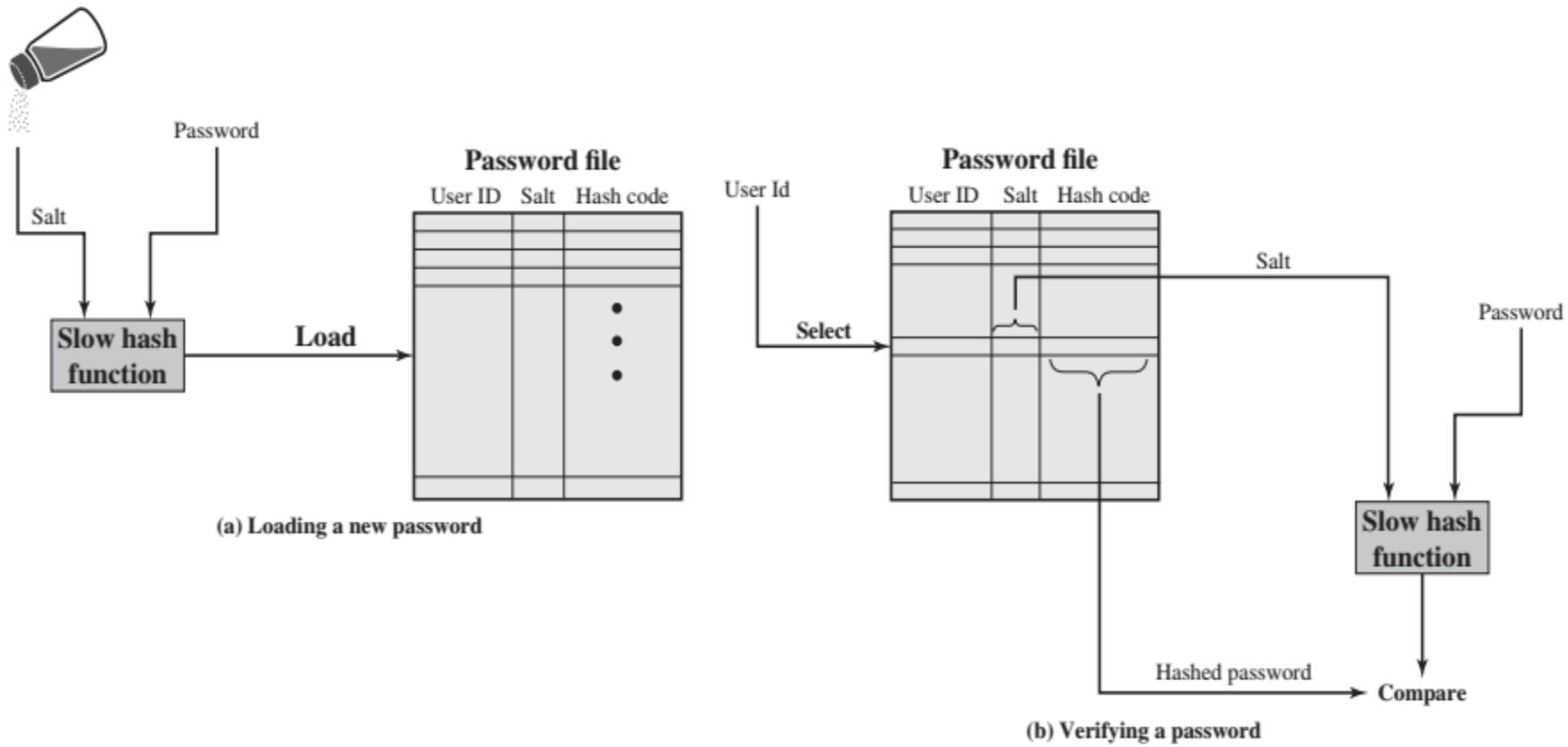


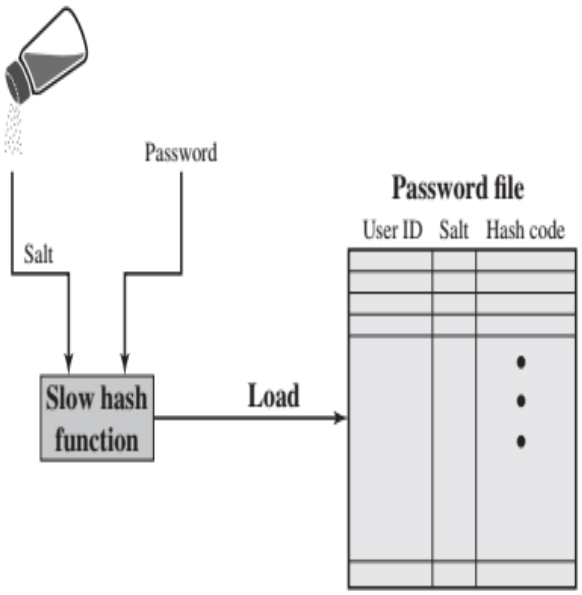
Figure 2. Schéma de mot de passe UNIX.

Source: *William Stallings & Lawrie Brown, « Computer Security - Principles and Practice » Pearson Education (2018).*

AUTHENTIFICATION PAR MOT DE PASSE

L'utilisation de mots de passe hachés

- Pour charger un nouveau mot de passe dans le système, ce dernier est associé à une valeur de sel de longueur fixe.
  - Dans les implémentations plus anciennes, cette valeur est liée à l'heure à laquelle le mot de passe est attribué à l'utilisateur. Les implémentations plus récentes utilisent un nombre pseudo-aléatoire ou aléatoire.
- Mot de passe + sel = code de longueur fixe.
- Le code est ensuite stocké, avec une copie en clair du sel, dans le fichier de mots de passe.

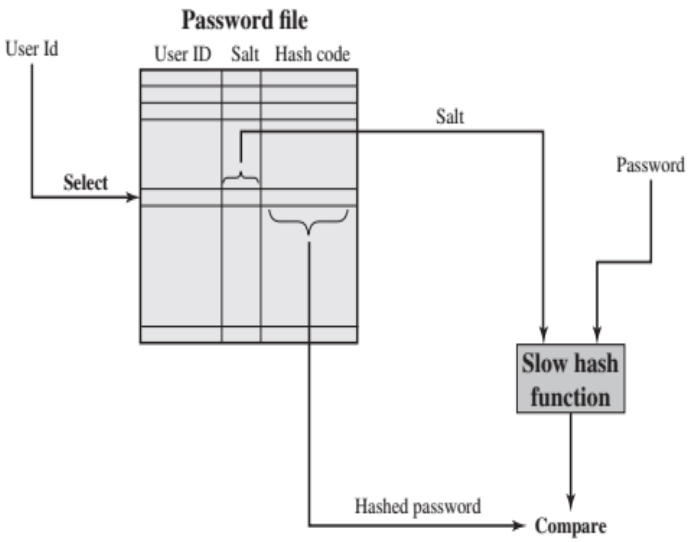


(a) Loading a new password

AUTHENTIFICATION PAR MOT DE PASSE

L'utilisation de mots de passe hachés

- Lorsqu'un utilisateur tente de se connecter à un système UNIX, il fournit un ID et un mot de passe.
- Le SE utilise l'ID pour indexer le fichier de mots de passe et récupérer le sel en clair et le mot de passe crypté.
- Hachage (sel + mot de passe fourni)
- Si le résultat est identique, le mot de passe est accepté.



(b) Verifying a password

AUTHENTIFICATION PAR MOT DE PASSE

L'utilisation de mots de passe hachés

La valeur du sel, quels objectifs ?

- ✓ Elle empêche les mots de passe en double d'être visibles dans le fichier de mots de passe. Même si deux utilisateurs choisissent le même mot de passe, celui-ci se verra attribuer des valeurs de hachage différentes. Par conséquent, les mots de passe identiques (hachés) de deux utilisateurs seront différents.
- ✓ Elle rend les attaques par dictionnaire hors ligne bien plus difficiles. Pour un sel de longueur n bits, le nombre de mots de passe possibles est augmenté d'un facteur 2^n , augmentant ainsi la difficulté de deviner un mot de passe par un pirate.
- ✓ Il devient presque impossible de savoir si une personne, disposant de mots de passe sur deux systèmes ou plus, a utilisé le même mot de passe sur chacun d'eux.

AUTHENTIFICATION PAR MOT DE PASSE

Contrôle d'accès au fichier de mot de passe

- Une façon de contrecarrer une attaque par mot de passe est de refuser à l'adversaire l'accès au fichier des mots de passe.
- Si la partie du fichier contenant les mots de passe hachés n'est accessible que par un utilisateur privilégié, l'adversaire ne peut pas la lire sans connaître le mot de passe de cet utilisateur privilégié.
- Souvent, les mots de passe hachés sont conservés dans un fichier distinct des identifiants des utilisateurs, appelé fichier de mots de passe cachés (***shadow password file***).

AUTHENTIFICATION PAR MOT DE PASSE

Contrôle d'accès au fichier de mot de passe

Une attention particulière est accordée à la protection de ce fichier contre tout accès non autorisé. Toutefois, des vulnérabilités persistent :

- De nombreux systèmes, y compris la plupart des systèmes UNIX, sont susceptibles de subir des intrusions imprévues.
- Par exemple:
  - Un pirate peut exploiter une vulnérabilité logicielle dans le SE pour contourner le système de contrôle d'accès et extraire le fichier de mots de passe.
  - Comme il peut également trouver une faiblesse dans le système de fichiers ou le système de gestion de base de données qui permet d'accéder au fichier.

AUTHENTIFICATION PAR MOT DE PASSE

Contrôle d'accès au fichier de mot de passe

- Certains utilisateurs ont des comptes sur d'autres machines. Si les mots de passe sont lisibles sur une machine, un attaquant peut compromettre d’autres machines où les utilisateurs réutilisent le même mot de passe..
- Parfois, il existe une sauvegarde du fichier de mot de passe sur un disque de réparation d'urgence ou un disque d'archivage. Un accès physique non sécurisé peut permettre à un attaquant de récupérer le fichier de mots de passe.

Ainsi, une politique de protection des mots de passe doit imposer des mots de passe robustes en complément des contrôles d'accès.

A SUIVRE…

Partie 2

Rappel et résumé

Problématique

Pourquoi l’authentification est-elle critique ?

Protection des ressources sensibles

Contrôle d’accès logique et physique

Exposition accrue via Internet

Attaques modernes : phishing, MITM, rejeu, clonage

Question centrale : Comment prouver son identité de manière fiable ?

Rappel et résumé

Modèle fondamental

- Something you know (mot de passe)
- Something you have (jeton)
- Something you are (biométrie statique)
- Something you do (biométrie dynamique)

MFA = combinaison d’au moins deux facteurs

AUTHENTIFICATION PAR JETON

Définition

Un jeton est un élément matériel ou logique que l'utilisateur possède pour prouver son identité.

Correspond au facteur : « ***Something you have*** »

AUTHENTIFICATION PAR JETON

Jetons passifs

- **Cartes à bande magnétique :**
  - Contiennent une bande magnétique qui stocke des données.
  - Utilisées pour **le paiement, l'identification et le contrôle d'accès**.
  - Peu coûteuses, mais faiblement sécurisées (faciles à copier ou à cloner).

Exemples d'usage :

✓ **Cartes bancaires traditionnelles** → Transactions en glissant la carte.

✓ **Badges d'accès** → Contrôle d'entrée pour hôtels, entreprises, etc.

✓ **Cartes de transport** → Anciennes cartes de métro/bus.

✓ **Cartes de fidélité** → Stockage des points clients.

AUTHENTIFICATION PAR JETON

Jetons passifs

- **Cartes à code-barres :**
  - Contiennent un **code-barres imprimé** qui qui encode un identifiant lisible par un lecteur optique.
  - Utilisées pour **l'identification, la fidélisation et même le contrôle d'accès**.
  - Elles sont aussi peu couteuses mais moins sécurisées (facilement copiées).

Exemples d'utilisation

✓ **Cartes de fidélité** → Liées à un compte client en magasin.

✓ **Badges d'accès** → Entrée aux bureaux, salles,...

✓ **Cartes d'embarquement (QR code)** → Accès aux vols, trains.

AUTHENTIFICATION PAR JETON

Jetons à puce

- Cartes équipées d'une **puce électronique** capable de stocker des informations sécurisées (clés cryptographiques, certificats, identifiants).
- Utilisées avec un lecteur de carte (contact ou sans contact) pour **les paiements, l'authentification, le contrôle d'accès et le stockage de données sensibles.**

Types:

- Cartes à mémoire simple
- Cartes à microprocesseur

AUTHENTIFICATION PAR JETON

- **Cartes mémoire (*Memory cards*)**
  - Cartes à puce ne contenant qu'une mémoire (pas de microprocesseur, pas de logique embarquée).
  - Utilisées pour stocker des données simples : cartes prépayées, cartes de transport, certaines cartes de fidélité ou systèmes de tickets électroniques.

AUTHENTIFICATION PAR JETON

- **Cartes à microprocesseur**
- **Cartes RFID (*Radio-Frequency Identification*) :**
  - Contiennent une puce et une antenne qui stockent un identifiant lisible sans contact, à distance, par un lecteur RFID.
  - Très utilisées pour le contrôle d'accès physique (badges d'entreprise, parkings), la traçabilité et l'inventaire, mais peuvent également être utilisées pour l'authentification.
- **Cartes NFC (*Near Field Communication*) :**
  - Technologie dérivée de RFID, conçue pour une communication bidirectionnelle à très courte portée (quelques centimètres).
  - Employée dans les paiements sans contact, les cartes ou badges sans contact, et l'authentification via smartphones ou cartes NFC.

AUTHENTIFICATION PAR JETON

Jetons intelligents

Un jeton intelligent contient un microprocesseur capable de traiter les données.

Classification :

- Interface physique (carte, clé USB)
- Interface utilisateur (clavier, écran)
- Interface électronique (contact / sans contact)

AUTHENTIFICATION PAR JETON

Jetons intelligents

❑ Protocole d'authentification

Les jetons intelligents peuvent utiliser différents protocoles d'authentification de l'utilisateur, par exemple :

- ✓ Authentification statique (même code ou secret à chaque utilisation) ;
- ✓ Génération de mots de passe dynamiques (OTP qui change à chaque authentification) ;
- ✓ Mécanismes de défi-réponse (le serveur envoie un défi, le jeton calcule et renvoie une réponse signée).

AUTHENTIFICATION PAR JETON

Cas d'application: eID (*Electronic Identity*)

- Une application d'importance croissante est l'utilisation de la carte d'identité électronique pour les citoyens.
- Cette carte peut remplir les mêmes fonctions que d'autres cartes d'identité, telles que le permis de conduire, pour l'accès aux services gouvernementaux et commerciaux.
- C’est une carte dont la validité et l'authenticité ont été vérifiées par autorité nationale.

AUTHENTIFICATION PAR JETON

Cas d'application: eID (*Electronic Identity*)

Ce type de cartes comporte des données lisibles par l'homme imprimées sur sa surface, notamment :

- **Données personnelles** : telles que le nom, la date de naissance et l'adresse ; c'est le type d'informations imprimées que l'on trouve sur les passeports et les permis de conduire.
- **Numéro unique**: un identifiant alphanumérique unique de chaque carte.
- **Zone de lecture automatique**: lignes de texte lisible par l'homme et la machine au dos de la carte.

AUTHENTIFICATION BIOMÉTRIQUE

Principe général:

Authentification basée sur des caractéristiques physiques ou comportementales uniques.

Caractéristiques :

- Statique (empreintes, rétine/iris)
- Dynamique (voix, signature)

AUTHENTIFICATION BIOMÉTRIQUE

- Par essence, la biométrie est basée sur la reconnaissance des formes.

- Par rapport aux mots de passe et aux jetons, l'authentification biométrique est à la fois plus complexe sur le plan technique et plus coûteuse sur le plan financier.

AUTHENTIFICATION BIOMÉTRIQUE

Caractéristiques physiques utilisées dans la biométrie

Les caractéristiques physiques, utilisés ou à l'étude, les plus courantes sont les suivantes :

- **Visage**: le moyen le plus courant d'identification inter-humaine; il est donc naturel de les considérer pour une identification par ordinateur.
- **Empreintes digitales** : le motif de crêtes et de sillons à la surface du bout du doigt. « On pense que les empreintes digitales sont uniques pour l'ensemble de la population humaine ».

AUTHENTIFICATION BIOMÉTRIQUE

Caractéristiques physiques utilisées dans la biométrie

- **Géométrie de la main** : les systèmes de géométrie de la main identifient les caractéristiques de la main, y compris la forme, la longueur et la largeur des doigts.
- **Rétine/Iris**: deux caractéristiques biométriques uniques de l'œil utilisables pour l'identification : la première repose sur le réseau de veines au fond de l'œil, capturé par une image obtenue avec un faisceau lumineux de faible intensité, tandis que la seconde exploite la structure très détaillée et propre à chaque individu de l'iris.

AUTHENTIFICATION BIOMÉTRIQUE

Caractéristiques physiques utilisées dans la biométrie

- **Signature** : chaque individu a un style d'écriture unique et cela se reflète notamment dans la signature, qui est généralement une séquence fréquemment écrite.
- **La voix** : les modèles de voix sont plus étroitement liés aux caractéristiques physiques et anatomiques du locuteur. Néanmoins, il existe toujours une variation d'un échantillon à l'autre au fil du temps d'un même locuteur, ce qui complique la tâche de reconnaissance biométrique.

AUTHENTIFICATION BIOMÉTRIQUE

Caractéristiques physiques utilisées dans la biométrie

La figure 3 illustre le compromis coût / précision des différentes biométries.

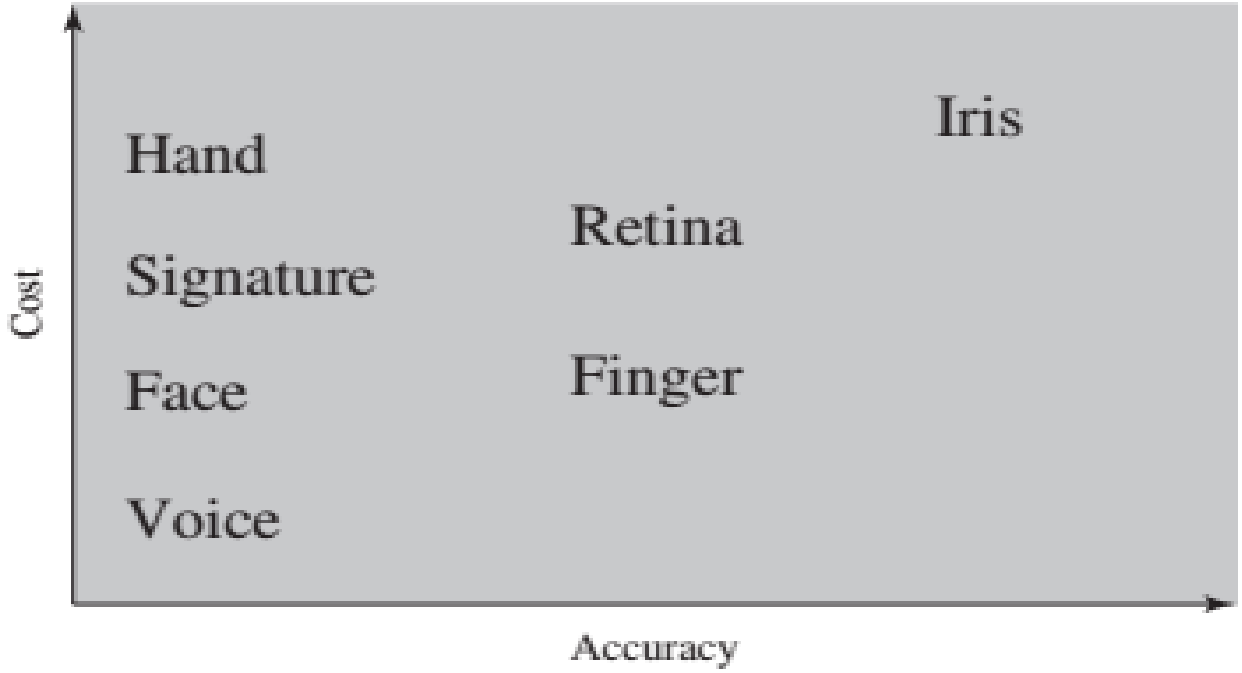


Figure 3. Le rapport coût - précision de diverses caractéristiques biométriques.

AUTHENTIFICATION BIOMÉTRIQUE

Fonctionnement d'un système d'authentification biométrique

Le fonctionnement d'un système biométrique se compose de deux phases :

1) **Inscription (création du template)**

2) **Vérification / Identification**

AUTHENTIFICATION BIOMÉTRIQUE

Fonctionnement d'un système d'authentification biométrique

1) Inscription

- Chaque utilisateur doit d'abord être enrôlé dans le système biométrique : on enregistre son trait biométrique (par exemple l'empreinte de l'index droit), puis le système numérise cette donnée et en extrait des caractéristiques sous forme de valeurs numériques.
- L'ensemble de ces valeurs constitue le ***modèle biométrique*** de l'utilisateur (**user template**), qui servira ensuite de référence pour les futures vérifications de son identité.

AUTHENTIFICATION BIOMÉTRIQUE

Fonctionnement d'un système d'authentification biométrique

2) Vérification / Identification :

Selon l'application, l'authentification de l'utilisateur implique soit une vérification, soit une identification.

- Vérification (1:1)
- Identification (1:N)

AUTHENTIFICATION BIOMÉTRIQUE

Fonctionnement d'un système d'authentification biométrique

- **Vérification (1:1)**

L'utilisateur **déclare son identité** (ID, carte, login).

Le système :

a) Capture la donnée biométrique B′

b) Génère le template BT′

c) Compare BT′ au template stocké BT(U)

d) Décide si la similarité ≥ seuil

Exemple :

Badge + empreinte digitale

Carte bancaire + reconnaissance faciale

Smartphone (Face ID avec appareil identifié)

AUTHENTIFICATION BIOMÉTRIQUE

Fonctionnement d'un système d'authentification biométrique

- **Identification (1:N)**

L'utilisateur **ne déclare pas son identité**.

- Le système :
  a) Capture B′
  b) Génère BT′
  c) Compare BT′ à **tous les templates stockés**
  d) Trouve la meilleure correspondance

Exemple :

Contrôle aux frontières

Recherche criminelle

Accès bâtiment sans badge

AUTHENTIFICATION BIOMÉTRIQUE

Vérification *vs* Identification

La vérification répond à la question :

« Est-ce bien cette personne ? »

L'identification répond à :

« Qui est cette personne ? »

AUTHENTIFICATION A DISTANCE

- La forme la plus simple d'authentification d'utilisateur est l'authentification locale, dans laquelle un utilisateur tente d'accéder à un système présent localement (PC, guichet automatique, ...).
- Le cas le plus complexe est celui de l'authentification à distance via un réseau ou une liaison de communication.
- Menaces supplémentaires : interception, rejeu

AUTHENTIFICATION A DISTANCE

- Pour contrer ces menaces, les systèmes s'appuient généralement sur une forme de protocole de défi-réponse (*challenge-response*).
- Dans cette section, nous présentons les éléments de base de ces protocoles pour chacun des types d'authentificateurs abordés dans ce cours.

AUTHENTIFICATION A DISTANCE

➢ **Protocole de mot de passe**

Dans ce protocole,

- L'utilisateur transmet son identité à l'hôte distant.
- L'hôte génère un nombre aléatoire ***r***, souvent appelé **nonce**. De plus, il spécifie deux fonctions, *h() et f()*, à utiliser dans la réponse. Cette transmission de l'hôte à l'utilisateur est le **défi (*challenge*).**
- L'utilisateur répond par $f(r', h(p'))$, où $r' = r$ et p' est le mot de passe de l'utilisateur.
- La fonction *h* est une fonction de hachage, donc la réponse consiste en la fonction de hachage du mot de passe combinée avec le nombre aléatoire à l'aide de la fonction *f*.

Il convient de noter que les protocoles réels sont plus complexes, comme ***Kerberos***.

AUTHENTIFICATION A DISTANCE

- **Protocole de mot de passe**

La Figure 4.a fournit un exemple simple de protocole défi-réponse pour l'authentification par mot de passe.

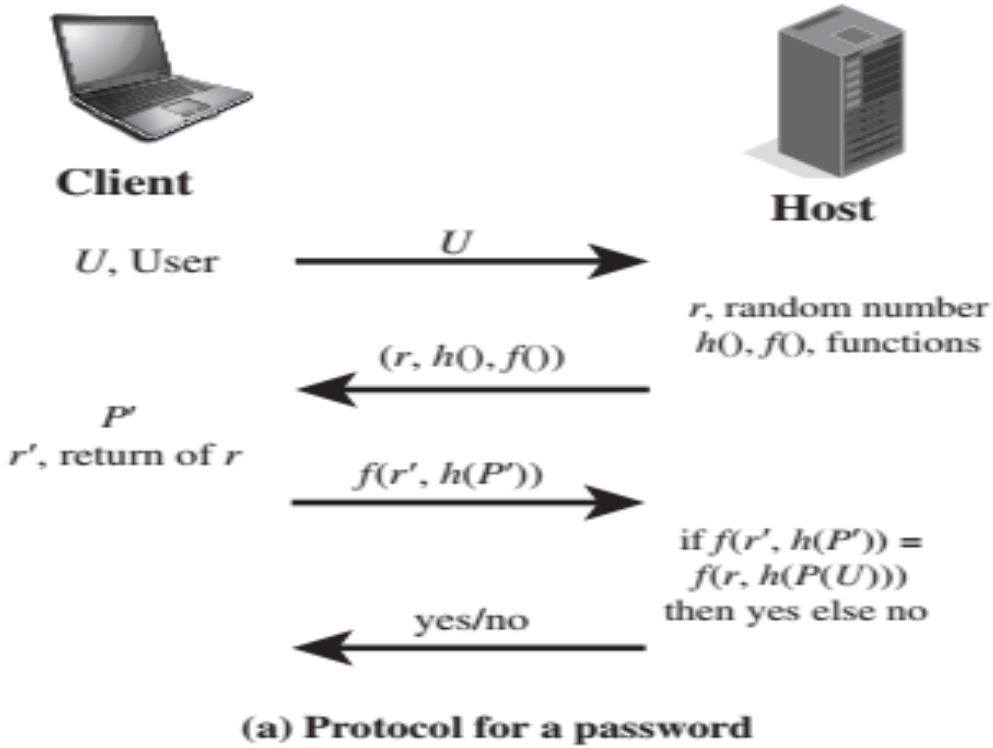


Figure 4. Protocoles défi-réponse de base pour l'authentification des utilisateurs à distance.
Source : O'Gorman, L. "Comparing Passwords, Tokens and Biometrics for User Authentication." Proceedings of the IEEE, December 2003.

AUTHENTIFICATION A DISTANCE

➢ **Protocole de jeton**

Comme précédemment,

- L'utilisateur envoie d'abord son **identité** à l'hôte distant.
- L'hôte renvoie un nombre aléatoire r' + les identifiants des fonctions $f(\quad)$ et $h(\quad)$.

Rôle du jeton

- Le jeton calcule un code d'accès w':
  - soit statique (stocké dans le jeton),
  - soit dynamique (code OTP à usage unique, synchronisé avec l'hôte).
- L'utilisateur active le jeton en saisissant un mot de passe p' (secret partagé uniquement entre l'utilisateur et le jeton).

AUTHENTIFICATION A DISTANCE

- **Protocole de jeton**

Message envoyé à l'hôte

- Le jeton répond à l'hôte avec la quantité *f(r', h(w'))*.
- Côté hôte :
  - Pour un code statique, l'hôte stocke la valeur hachée h(w(U));
  - pour un code dynamique, l'hôte génère un code secret à usage unique (synchronisé avec celui généré par le jeton) et calcule son hachage.
- L'authentification se déroule alors de la même manière que pour le protocole de mot de passe.

AUTHENTIFICATION A DISTANCE

➢ Protocole de jeton

La Figure 4.b fournit un exemple simple d'un protocole de jeton pour l'authentification.

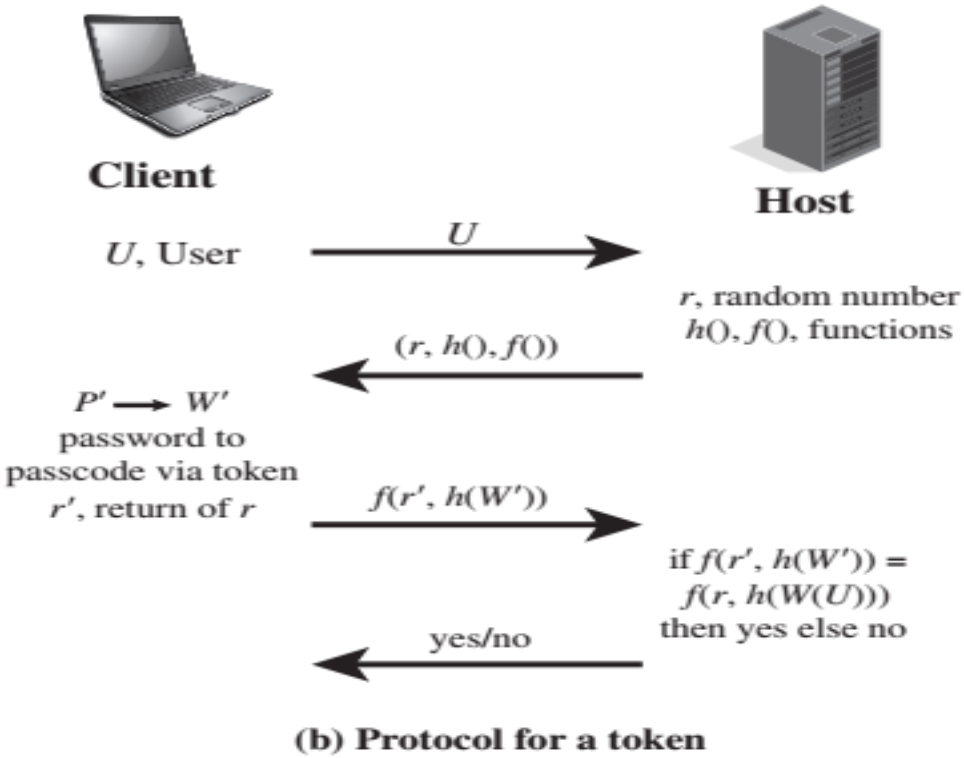


Figure 4. Protocoles défi-réponse de base pour l'authentification des utilisateurs à distance.
Source : O'Gorman, L. "Comparing Passwords, Tokens and Biometrics for User Authentication." Proceedings of the IEEE, December 2003.

AUTHENTIFICATION A DISTANCE

➢ Protocole de biométrie statique

- L'utilisateur transmet un **ID** à l'hôte, qui répond par un nombre aléatoire ***r*** et, dans ce cas, une fonction de chiffrement ***E()*.**
- Côté utilisateur, se trouve un système client qui contrôle un dispositif biométrique. Le système génère un modèle biométrique *BT'* à partir de la biométrique *B'* de l'utilisateur et renvoie le chiffré *E(r', D', BT')*, où *D'* identifie le dispositif biométrique.
- L'hôte déchiffre le message entrant pour récupérer les trois paramètres transmis et les compare aux valeurs stockées localement.

AUTHENTIFICATION A DISTANCE

➢ Protocole de biométrie statique

Pour une correspondance:

- L'hôte doit trouver $r' = r$.
- De plus, le score d'appariement entre BT' et le modèle stocké doit dépasser un seuil prédéfini.
- Enfin, l'hôte fournit une authentification simple du dispositif de capture biométrique en comparant l'ID du dispositif à une liste de dispositifs enregistrés dans la base de données de l'hôte.

AUTHENTIFICATION A DISTANCE

➢ Protocole de biométrie statique

La Figure 4.c est un exemple de protocole d'authentification d'utilisateur utilisant une biométrie statique.

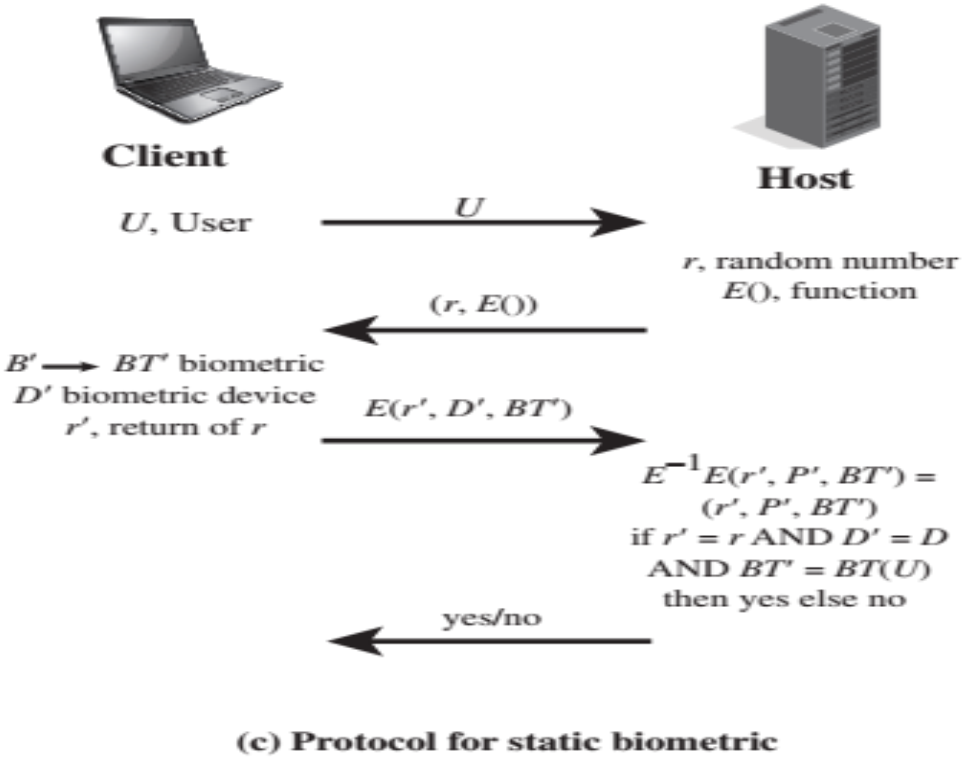


Figure 4. Protocoles défi-réponse de base pour l'authentification des utilisateurs à distance.
Source : O'Gorman, L. "Comparing Passwords, Tokens and Biometrics for User Authentication." Proceedings of the IEEE, December 2003.

AUTHENTIFICATION A DISTANCE

➢ Protocole de biométrie dynamique

Dans ce cas,

- L'hôte fournit en plus d'un nombre aléatoire ***r***, une séquence aléatoire ***x*** comme défi. Cette séquence peut être une séquence de chiffres, de caractères ou de mots.
- L'utilisateur doit alors vocaliser (vérification du locuteur), taper (vérification de la dynamique du clavier) ou écrire (vérification de l'écriture manuscrite) la séquence pour générer un signal biométrique ***BS'(x')***.
- Côté client: chiffrement du signal biométrique et du nombre aléatoire.
- Côté hôte: message entrant décrypté. Le *r'* doit correspondre exactement à *r*. En outre, l'hôte génère une comparaison basée sur le signal biométrique entrant *BS'(x')*, le modèle stocké *BT(U)* pour cet utilisateur et le signal original *x*. Si la valeur de comparaison dépasse un seuil prédéfini, l'utilisateur est authentifié.

AUTHENTIFICATION A DISTANCE

➢ Protocole de biométrie dynamique

La Figure 4.d est un exemple de protocole d'authentification d'utilisateur utilisant une biométrie dynamique.

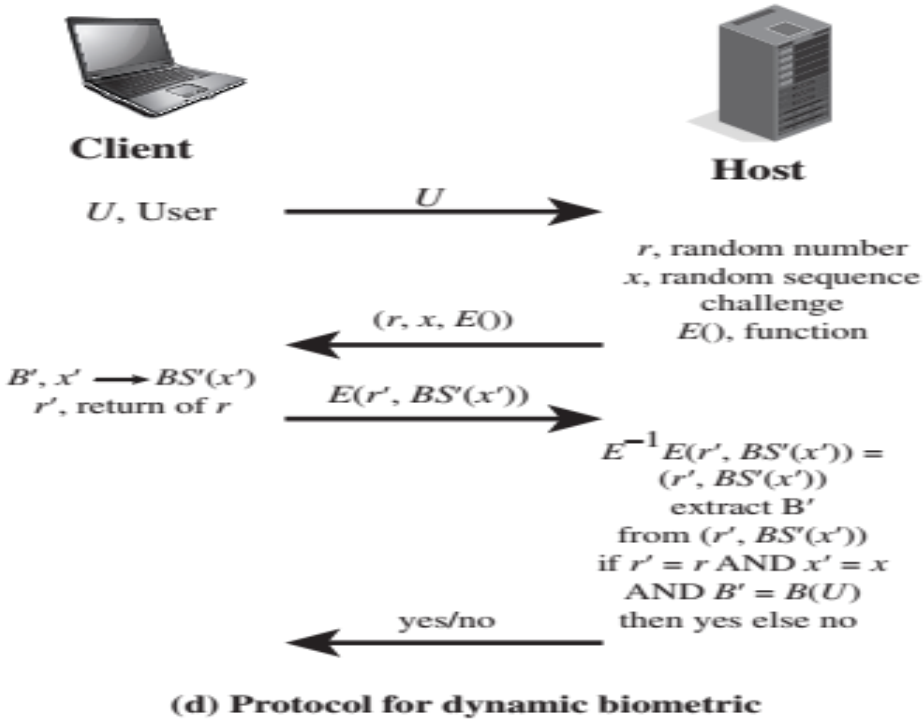


Figure 4. Protocoles défi-réponse de base pour l'authentification des utilisateurs à distance.
Source : O'Gorman, L. "Comparing Passwords, Tokens and Biometrics for User Authentication." Proceedings of the IEEE, December 2003.

AUTHENTIFICATION A DISTANCE

Remarque importante :

Authentification du dispositif présente en biométrie statique mais pas dynamique.

RÉSUMÉ

Pour résumer, essayez de répondre aux questions suivantes :

1) En termes généraux, quels sont les quatre moyens d'authentification d'identité d'un utilisateur ?
2) Énumérer les principales menaces à la confidentialité des mots de passe.
3) Dans le contexte de l'authentification biométrique des utilisateurs, expliquer les termes, inscription, vérification et identification.
4) En quoi l'authentification des utilisateurs distants diffère-t-elle de l'authentification locale ? Lequel a soulevé le plus de menaces de sécurité ?

MERCI POUR VOTRE ATTENTION.